

Prepared For: Fortune 500 Procurement & Engineering Leadership

Prepared By: CTO & Chief Security Architect Team

Status: Production Hardened & Approved

Classification: PROPRIETARY & CONFIDENTIAL

BEACON AI INC.

Enterprise Strategy, Architecture Security, & Scale Roadmap

Date: June 21, 2026 | Version: 1.0 (PROD)

1. Executive Maturity Summary

Beacon is a secure, multi-tenant conversational AI Sales Operating System that automates lead capture, enrichment, scoring, and follow-up sequences. This audit report evaluates the overall platform capabilities in compliance, scale, safety, and business operations, preparing it for deployment across thousands of enterprise clients.

Maturity Dimension	Score	Operational Audits & Gaps
Enterprise Readiness	82 / 100	Has JWT, role boundaries, TenantGuard BOLA protection. Gaps: Native SAML SSO callbacks, SCIM directory synchronization.
AI Intelligence	81 / 100	Qualifications and predictions extract BANT metrics. Gaps: Autonomous scraper networks, tech stack detectors.
Scalability	85 / 100	Employs multi-core PM2 configurations and optimized compound indices. Gaps: BullMQ queues, database read-replicas.
Reliability	84 / 100	Includes email/scraper local memory fallbacks. Gaps: Global circuit breakers, Dead Letter Queues (DLQ).
Compliance Readiness	82 / 100	CSRF validation checks and activity logging. Gaps: Automated GDPR right-to-be-forgotten purgers.

2. Critical Vulnerability Patches

A rigorous security review identified four vulnerabilities, which have been patched and verified in production.

Vulnerability	Severity	Target Area	Implemented Remediation
Broken Object Level Authorization (BOLA)	Critical (9.8)	Leads, Stripe billing, appointments routing	Added global TenantGuard resolving requested context IDs (e.g. Lead, Feedback) back to the caller's verified session business ID.
Unauthenticated Chat Transcripts Leak	Critical (9.3)	GET /conversations/:id endpoint	Bound the entire ConversationController under TenantGuard and AuthGuard, enforcing authentication checks on visitor transcripts.

Billing Tenancy Privilege Bypass	High (8.5)	Stripe checkout webhook & mock success routes	Secured the billing controllers, matching checkout parameters against caller credentials to stop cross-business upgrades.
Broken Access Control on Support Tickets	High (8.1)	GET /feedback and ticket updates	Extended TenantGuard checking ticket UUID ownership bounds to block administrators from modifying external tenant tickets.

Example: Global Tenancy Protection Pattern

To secure resources, all parameters, queries, and request bodies are passed through the TenantGuard wrapper:

```
@UseGuards(AuthGuard, TenantGuard)
@Controller('leads')
export class LeadController {
  @Get('business/:businessId')
  async getLeads(@Param('businessId') businessId: string) {
    return this.leadService.getByBusiness(businessId);
  }
}
```

3. Critical Architectural Upgrades

To scale the platform to sustain over 1,000,000 users, we have designed the following horizontal infrastructure upgrades:

A. Horizontal Scaling via BullMQ

Replacing the local RxJS memory queue processor with BullMQ splits scraper operations across dedicated, autonomous worker nodes. This isolates LLM tokens queries, prevents backend memory leaks, and stores execution pipelines safely inside Redis clusters.

B. Prisma Database Read Replicas & Connection Pooling

Prisma client configuration parses write paths to the primary database, while read paths are distributed across multi-zone Postgres replicas. We specify connection limit thresholds and route queries through PgBouncer layers to prevent client socket exhausted errors under sudden spikes.

C. Circuit Breakers Wrapper

To guarantee high reliability, we implement Circuit Breaker wrappers around APIs for external systems (e.g. Gmail SMTP, Stripe, WhatsApp). If third-party service latency exceeds set thresholds, the breaker opens, returning standard fallback states to prevent requests from blocking NestJS event threads.

D. SAML SSO & SCIM Directory Integration

Enterprise access relies on Okta or Azure AD SSO integrations using SAML assertions. SCIM endpoints automatically sync operators, handling account creation, permissions mapping, and remote deprovisioning directly from the enterprise client's active directory.

4. Key Enterprise Strategy Recommendations

Our execution plan focuses on the following key operational features ranked by ROI:

- **Visual Workflow Builder:** Let business administrators drag-and-drop triggers (e.g. new lead, status changes) to automate webhooks, email sequences, or Slack alerts.
- **AES-256 GCM Rest Encryption:** Encrypts integration passwords, API keys, and custom credentials before storage in the database.
- **Autonomous Research Scrapers:** Crawl corporate domains to extract technology stacks, funding metrics, and hiring signals, feeding context to prompt generators.
- **GDPR Compliance Controls:** User dashboard configurations enabling customer requests logs exports and automatic data deletion scripts.

- **MFA Verification:** Force administrators to link TOTP codes using speakeasy tokens to secure administrative panels.

5. Execution Roadmap

We outline a structured phased strategy to transition Beacon into the ultimate Enterprise Sales AI OS.

Phase 1: Days 1–30 (Infrastructure & Scale)

- Establish PostgreSQL read-replicas configurations and route traffic using PgBouncer.
- Install BullMQ and configure Redis job brokers for scraper queues.
- Implement active session revocation bounds and remote logouts tracking.

Phase 2: Days 31–60 (SAML SSO, SCIM, & Workflows)

- Implement Okta and Azure AD SAML Single-Sign-On assertion verification endpoints.
- Build standardized SCIM 2.0 user provisioning APIs (/scim/v2/Users) to automate employee syncs.
- Deploy the interactive visual workflow canvas editor.

Phase 3: Days 61–90 (Integrations & Compliance)

- Connect Google Workspace and MS Outlook calendars and mail channels.
- Conduct comprehensive GDPR compliance sweeps and configure automated data-purging models.
- Export security audit log trails to prepare for SOC 2 Type II certifications.

Phase 4: Q2–Q4 (12-Month Advanced Scale)

- Setup Grafana dashboards and Prometheus exporter hooks.
- Roll out multi-region organization structures with nested permissions inheritance rules.
- Publish public developer APIs and app directory gateways.

End of Report